

RiskWaiver360

GRC Process Exception & Policy Waiver Management Platform

Final Hackathon Submission Documentation

Société Générale Technology Hackathon — PS1

RiskWaiver360 — GRC Process Exception & Policy Waiver Management Platform

Final Hackathon Submission Documentation

Société Générale Technology Hackathon — PS1: GRC Process Exception & Policy Waiver Management

Table of Contents

1. Project Title
2. Problem Statement
3. Business Objective
4. System Architecture
5. User Roles
6. Core Workflow
7. Main Features
8. Risk Scoring Model
9. Alert System
10. GRC Intelligence
11. Compliance Alignment
12. CIA Triad Mapping
13. Audit Readiness

14. Technology Stack
 15. Run Instructions
 16. Demo Accounts
 17. Prototype Limitations
 18. Production Roadmap
 19. Future AI Enhancements
 20. Conclusion
-

1. Project Title

RiskWaiver360 — GRC Process Exception & Policy Waiver Management Platform

RiskWaiver360 is a full-stack working prototype that centralizes every security policy exception and waiver into a single trusted system — with risk scoring, lifecycle tracking, alert monitoring, conflict detection, and one-click audit-ready reporting.

2. Problem Statement

The Enterprise Reality

In most enterprises today, security policy exceptions — commonly called "waivers" — are not formally managed. They live in:

- **Emails** between security teams and business units
- **Excel spreadsheets** shared over file shares or email
- **Slack and chat messages** that disappear over time
- **Verbal approvals** with no recorded evidence
- **Informal PDF forms** stored in unindexed folders

This informal approach creates serious, compounding risks:

Core Failure Patterns

Failure	Impact
Scattered exception records	No single source of truth; leadership cannot answer "who currently holds which exception, and why?"
Temporary exceptions become permanent	A "2-week firewall opening" approved in 2022 is still active in 2025 because nobody tracked the expiry
Expired exceptions are never revoked	Active sessions, firewall rules, and encryption waivers remain open long after the business need has passed
No accountability for owners	When the employee who owned an exception leaves, the exception becomes orphaned — active with no responsible party
Vague justifications	"Needed for business" or "testing" justifications are approved without scrutiny, creating undocumented risk
Risk accumulation	Ten individually "low" exceptions on one system combine into a critical, invisible exposure that no one is tracking holistically
Audit failures	When an auditor asks "show every exception, who approved it, why, and evidence it has been reviewed," teams fail even if nothing was breached
Conflicting approvals	One approver approves an exception another has rejected — nobody detects the conflict
Overlapping waivers	Two teams raise separate exceptions for the same asset and policy — creating ambiguity and double-counted risk

Why This Matters Now

Regulatory standards such as NIST AC-2, GDPR Article 25, and CIS Controls explicitly require that policy deviations be documented, justified, time-limited, reviewed, and revoked when no longer needed. Enterprises that cannot demonstrate this control fail audits, face regulatory penalties, and carry hidden attack paths in their security posture.

3. Business Objective

RiskWaiver360 addresses every failure pattern listed above through a single, integrated platform with the following objectives:

Primary Objectives

1. **Centralize** all security policy exceptions into one searchable, structured registry — eliminating email and Excel chaos
2. **Score risk** for every exception using a transparent, explainable rule-based model — giving security teams a prioritized view of where risk is highest
3. **Track lifecycle** through formal states (submitted → reviewed → approved → active → expiring → renewed/revoked) — preventing temporary exceptions from becoming permanent
4. **Monitor expiry** and ownership continuously — generating automatic alerts before exceptions lapse or become orphaned
5. **Detect conflicts** — surface overlapping exceptions, duplicate waivers, and conflicting approvals that no spreadsheet would catch
6. **Generate audit evidence** — produce a complete, immutable record of every decision, comment, action, and risk score for every exception, ready for auditor review in one click

Business Value Delivered

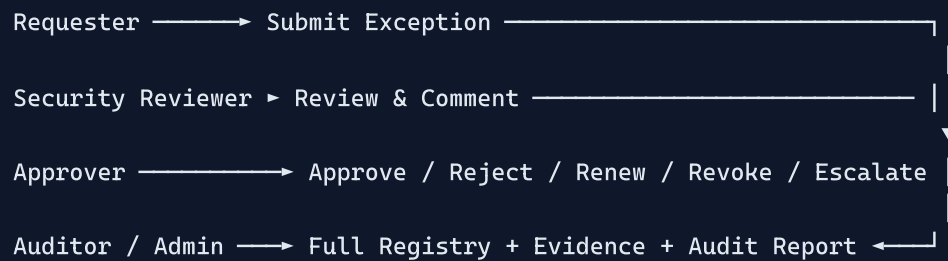
Business Need	How RiskWaiver360 Delivers It
Visibility into active exceptions	Centralized registry + portfolio dashboard with risk heatmap
Expiry and renewal governance	Automatic expiry tracking, expiring_soon / overdue statuses, alert engine
Risk prioritization	0–100 risk score, four risk bands, top-risk rankings, hotspot analysis
Operational efficiency	Recommendations (revoke/renew/escalate) with owner, review queue, CSV import from existing spreadsheets
Audit readiness	One-click audit report with executive summary, compliance roll-ups, conflict findings, immutable timeline, and print/export

4. System Architecture

Architecture Overview



Role-Based Access Flow



Key Design Decisions

- **Frontend never holds fake data** — every page fetches live from the backend with loading/error/success states
- **Single proxy** — Vite dev server proxies `/api` to `:4000`, no CORS config needed during development
- **JSON file storage** — no database required to run, making the prototype instantly runnable on any machine with Node.js
- **Seed-based reset** — `npm run reset-demo` restores the original dataset from `backend/seed/` for clean demo runs

5. User Roles

RiskWaiver360 implements four distinct roles that mirror a real enterprise GRC workflow.

Requester

Who: Any employee or team that needs a temporary policy exception to do their job.

What they can do:

- Submit new exception requests via the structured GRC Intake Form
- Provide business justification, select affected asset and policy, set start/expiry dates
- Specify compensating controls they have in place
- Track the status of their own submitted requests on My Requests page
- View the current risk score and recommendation assigned to their exception
- See alerts related to their exceptions

What they cannot do:

- Approve, reject, revoke, or renew any exception
- View other users' exceptions (scoped access in the frontend)

- Access the Audit Report or Review Queue
- Access the Admin or GRC Intelligence views

Main pages:

- My Requests (own exceptions only)
 - Add Exception (GRC Intake Form)
-

Security Reviewer

Who: Security analyst or GRC team member who performs initial triage of submitted requests.

What they can do:

- View all submitted exceptions in the Review Queue
- Add review comments and questions for the requester
- Move exceptions to `under_review` status
- Forward to approver for a decision
- View risk score breakdown and CIA triad impact
- Assess compensating controls

What they cannot do:

- Make final approval or rejection decisions
- Revoke or renew active exceptions
- Access full audit reporting

Main pages:

- Review Queue
 - Exception Details (for exceptions assigned to them)
 - Risk Scoring (to understand scoring logic)
-

Approver

Who: Manager, CISO delegate, or risk owner with authority to grant or deny exceptions.

What they can do:

- Approve or reject exceptions pending a decision
- Renew expiring or expired exceptions with a new expiry date
- Revoke active exceptions when the business need ends
- Escalate critical or disputed exceptions
- View the full exception registry and all lifecycle history
- See risk scores, GRC intelligence, and alerts

What they cannot do:

- Access the formal Audit Report (Auditor role required)
- Submit new exception requests as themselves

Main pages:

- Review Queue (approval decisions)
 - Exception Details (lifecycle actions)
 - Dashboard (portfolio overview)
 - GRC Intelligence
 - Alerts
-

Auditor / Admin

Who: Internal auditor, external auditor, CISO, or compliance officer who needs a complete, evidence-ready view.

What they can do:

- View the complete exception registry (all statuses, all business units)
- Access full exception history and audit timeline for any exception
- Read the Audit Report with executive summary, roll-ups, and conflict findings
- Print or export the audit report
- View all alerts, risk scores, GRC intelligence findings
- Access Settings and system configuration
- View the demo configuration and scoring parameters

What they cannot do:

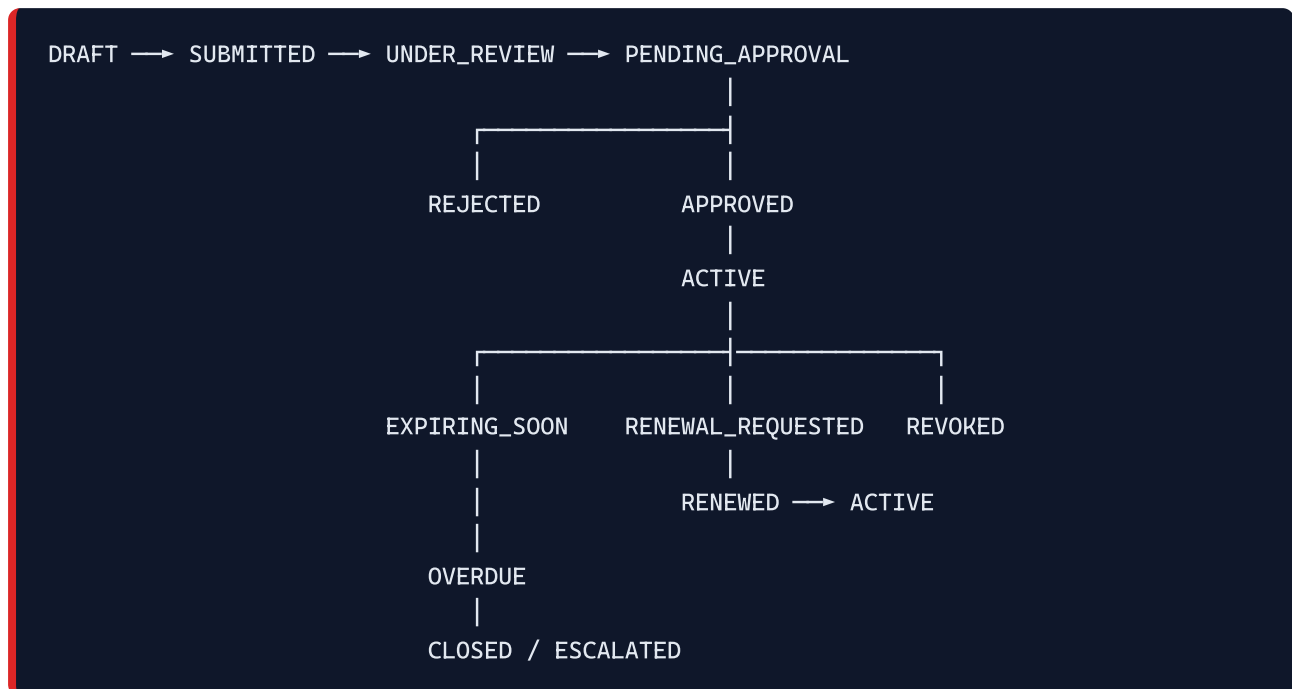
- Submit exceptions or perform lifecycle actions (read-only role in the demo)

Main pages:

- Dashboard (full portfolio view)
 - Exception Registry (full visibility)
 - Audit Report (print/export)
 - GRC Intelligence
 - Alerts
 - Risk Scoring
 - Settings
-

6. Core Workflow

Exception Lifecycle State Machine



Every state transition appends an immutable record to `exception_history` capturing: action, actor, timestamp, and note. This is the audit trail.

Step-by-Step Workflow

Step 1 — Requester submits

The Requester fills the GRC Intake Form: selects policy, asset, exception type, enters business justification, start/expiry date, compensating control, and owner. On submission, the backend scores the risk automatically and sets status to `submitted`.

Step 2 — Security Reviewer triages

The Security Reviewer opens the Review Queue, reads the justification and risk score, may add comments or ask clarifying questions, and forwards to the approver.

Step 3 — Approver decides

The Approver reviews the exception details including risk score, CIA impact, and reviewer comments. They can:

- **Approve** → exception becomes `active`
- **Reject** → exception is `rejected` with a recorded reason
- **Escalate** → exception moves to `escalated` for senior review
- **Ask for more information** → status returns to `under_review`

Step 4 — Active monitoring

Once **active**, the exception is continuously monitored. The alert engine evaluates it for:

- Approaching expiry (**expiring_soon**)
- Missed renewal (**overdue**)
- Orphaned owner
- Missing compensating control
- Overdue review

Step 5 — Renewal or Revocation

Before expiry, the Approver can renew with a new expiry date. When the business need ends (or the exception is overdue), the Approver revokes it — which is recorded with actor, timestamp, and reason.

Step 6 — Audit

The Auditor accesses the Audit Report at any time, which compiles the full portfolio: active exceptions, expired, revoked, risk distribution, compliance roll-ups, conflict findings, and a complete evidence timeline per exception.

7. Main Features

7.1 Exception Registry

The central searchable table of all exceptions in the system.

- Displays: Exception ID, Requester, Business Unit, Policy, Asset, Risk Score + Level badge, Status badge, CIA badge, Conflict flag, Expiry date, Actions
- Filters: search text, risk level (Low/Medium/High/Critical), status, business unit, policy category, has conflicts
- Click any row to open the full Exception Details page
- Supports CSV import (bulk upload from spreadsheets) and CSV export (full registry with risk scores)

7.2 Structured GRC Intake Form (Add Exception)

A multi-step, validated form for submitting new exception requests.

- Requester information, business unit, asset selection, policy selection
- Exception type (Admin Access, Encryption Disabled, Firewall Bypass, etc.)
- Business justification (free text, required)
- Start date and expiry date

- Compensating controls (mitigating factors)
- Owner name and approver selection
- On submission: backend auto-scores risk, sets **submitted** status, creates first history entry

7.3 Review Queue

Prioritized list of exceptions awaiting a decision, used by Security Reviewer and Approver.

- Shows all in-flight exceptions (submitted, under_review, pending_approval)
- Risk score and level visible at a glance for triage priority
- Actions: Approve, Reject, Request More Information, Add Comment
- Each action is recorded in the audit timeline

7.4 Exception Details / Evidence File

The full record for one exception — the primary audit artifact.

- Full metadata: requester, BU, policy, asset, type, dates, owner, approver
- Risk score with point-by-point factor breakdown and plain-English explanation
- CIA Triad impact badge
- Compensating controls status
- Conflict and overlap flags
- Lifecycle action buttons (role-specific: what this user can do now)
- Immutable audit timeline: every action, comment, approval, and status change with actor + timestamp
- Related alerts panel
- Related conflicts panel (if any overlap/conflict detected)

7.5 Risk Scoring Engine

Dedicated page explaining the scoring model and showing ranked exceptions.

- Live formula display
- Full factor weight table (reference)
- Ranked list of all exceptions, each showing its individual factor breakdown:
 - Exception Type weight
 - Asset Criticality weight
 - Duration penalty
 - Expiry Status penalty
 - Review Status penalty

- Owner Status penalty
- Compensating Control bonus (deducted)
- Plain-English explanation for each exception's score

7.6 Alerts / Continuous Monitoring

Live alert engine that continuously evaluates every active exception.

- **7 alert types:** Expiring Soon, Overdue, Orphaned Owner, Missing Compensating Control, Review Overdue, Critical Risk, Vague Justification
- Severity levels: Critical, High, Medium, Low
- Filters by severity and alert type
- Each alert links directly to the affected exception
- Simulated email reminder: shows a rendered email preview for expiry reminders (no real email sent — demo simulation only)

7.7 GRC Intelligence Center

Advanced analysis layer for detecting patterns that rule-by-rule checking misses.

- **Overlapping exceptions:** two or more exceptions covering the same asset and policy
- **Conflicting approvals:** one exception approved where another was rejected for the same scope
- **Duplicate waivers:** near-identical exception requests submitted by different requesters
- **Risk accumulation hotspots:** business units, assets, or owners with a disproportionate share of exception risk
- **Remediation plan:** ranked list of recommended actions with owner assignment

7.8 Audit Report

One-click, print-ready report for auditors and compliance officers.

- Executive summary with key metrics (active, overdue, orphaned, avg risk score)
- Posture overview: on-track vs. at-risk vs. critical exceptions
- Roll-ups by policy category, business unit, and owner
- Compliance alignment summary (NIST, GDPR, CIS)
- Overlap and conflict findings
- Top 10 riskiest exceptions
- Overdue and orphaned exceptions lists
- Recommendations summary

- Print / Export button (browser print dialog, generates PDF)

7.9 Portfolio Dashboard

Leadership-level portfolio view.

- 8 summary KPI cards: Total, Active, Overdue, Orphaned, Expiring Soon, Avg Risk Score, Critical Count, Reviewed
- 6 charts: Risk Distribution (pie), Status Distribution (bar), By Policy Category, By Exception Type, Top Risky Business Units, Monthly Trend
- Risk Heatmap (department × risk level, only showing columns with data)
- Top-risk exception table
- Risk hotspot cards

7.10 Settings / Demo Configuration

- Role switcher (demo convenience)
- Live backend status indicator
- Risk scoring parameter reference (band definitions, factor weights)
- User and owner status table
- System status overview

8. Risk Scoring Model

Formula

```
Risk Score = TYPE_WEIGHT
             + ASSET_CRITICALITY_WEIGHT
             + DURATION_PENALTY
             + EXPIRY_STATUS_PENALTY
             + REVIEW_STATUS_PENALTY
             + OWNER_STATUS_PENALTY
             - COMPENSATING_CONTROL_BONUS
```

(Result capped between 0 and 100)

Factor Weights

Factor	Values and Weights
Exception Type	Admin Access: 35 · Encryption Disabled: 35 · Firewall Bypass: 30 · Data Access Extension: 25 · Password Policy: 20 · Audit Logging Disabled: 25 · Network Exposure: 28 · Privileged Access: 32
Asset Criticality	Critical: 25 · High: 18 · Medium: 10 · Low: 5
Duration	≤7 days: 0 · ≤30 days: 5 · ≤90 days: 10 · ≤180 days: 15 · >180 days: 20
Expiry Status	Active/valid: 0 · Expiring within 7 days: 8 · Overdue: 15 · No expiry set: 10
Review Status	Reviewed recently: 0 · Not reviewed: 8 · Review overdue: 12
Owner Status	Owner present and active: 0 · Owner inactive/missing: 10 · No owner set: 12
Compensating Control	Control present: –15 · No control: 0

Risk Bands

Score Range	Risk Level	Meaning	Typical Action
0 – 30	Low	Minimal risk, controls in place, short duration	Monitor; standard renewal
31 – 60	Medium	Moderate risk; some factors elevated	Review before renewal; add controls
61 – 80	High	Significant risk; multiple elevated factors	Escalate; owner must confirm
81 – 100	Critical	Severe risk; immediate attention required	Revoke or escalate immediately

Design Philosophy

The current risk scoring model is **fully rule-based and explainable**. Every point in an exception's score can be traced to a specific factor with a specific weight. This is intentional:

- Security teams can audit the scoring logic without a data science background
- Judges and auditors can verify why a score of 95 was assigned
- No black-box AI is involved in scoring decisions

The system is architected to later add AI-based layers (see Section 19), but the current prototype prioritises explainability over complexity.

9. Alert System

Overview

The alert engine runs on every API request, evaluating every active exception against seven rule-based conditions. Alerts are not stored permanently — they are recomputed live so they always reflect the current state of the exception registry.

Alert Types

Alert Type	Trigger Condition	Severity
Expiring Soon	Expiry date is within 7 days and exception is still active	High
Overdue	Expiry date has passed and exception has not been renewed or revoked	Critical
Orphaned Owner	The owner on record has left the organisation or is marked inactive	High
Missing Compensating Control	Exception has no compensating control recorded, especially for Critical assets	Medium–High
Review Overdue	Exception has not been reviewed within the required review cycle	Medium
Critical Risk	Risk score ≥ 81 and exception remains active without escalation	Critical
Vague Justification	Business justification is shorter than a threshold or uses flagged phrases ("testing", "needed for business")	Low–Medium

Email Reminder Simulation

The Alerts page includes a simulated email reminder that shows exactly what an automated notification to an exception owner would look like — including the exception ID, risk level, expiry date, and a call-to-action link.

Important: No real email is sent. This is a demo simulation only. In a production deployment, the email content shown would be delivered via an SMTP gateway, SendGrid, or an enterprise email system (Exchange/O365).

10. GRC Intelligence

Overview

GRC Intelligence goes beyond individual exception alerts to detect **cross-exception patterns** — problems that only become visible when looking at the full portfolio together.

Detection Categories

Overlapping Exceptions

Two or more exceptions that cover the same asset and the same policy, both in an active or approved state simultaneously. Overlap creates ambiguity about which exception's controls apply and which approval takes precedence.

Conflicting Approvals

One approver has approved an exception for a scope that another approver has rejected. This indicates inconsistent risk tolerance and can undermine the integrity of the exception governance process.

Duplicate Waivers

Near-identical exception requests submitted separately by different requesters for the same scope. Duplicates suggest a communication breakdown and result in double-counted risk.

Risk Accumulation Hotspots

Analysis of the total combined risk held by a single asset, business unit, owner, or policy. An asset with five individually-Medium exceptions may have a combined exposure equivalent to a Critical risk. Hotspots are ranked by total accumulated risk score.

Remediation Plan

The GRC Intelligence Center produces a prioritised remediation action list: which exception to address first, what action to take (revoke, escalate, merge, renew), and who owns the action.

Where Findings Surface

- GRC Intelligence dedicated page (full analysis)
- Portfolio Dashboard (summary cards and top findings)
- Exception Details page (related conflicts panel per exception)
- Exception Registry (conflict flag badge and filter)
- Audit Report (conflict findings section)

11. Compliance Alignment

RiskWaiver360 is designed to support compliance with the following standards and frameworks:

NIST SP 800-53 — AC-2 (Account Management)

Requirement: Privileged and admin account access must be controlled, periodically reviewed, and revoked when no longer needed.

How RiskWaiver360 supports it:

- Admin Access and Privileged Access exception types carry the highest type weight (35 and 32 points respectively) in the risk scoring model
- Review Overdue alerts fire when admin access exceptions have not been reviewed within cycle
- Every approval, review, and revocation is logged with actor and timestamp
- The Audit Report includes a roll-up of admin-access exceptions with review status

NIST SP 800-53 — PL-4 (Rules of Behavior)

Requirement: Policy deviations must be documented, justified, and formally acknowledged.

How RiskWaiver360 supports it:

- Mandatory business justification field on every exception request
- Vague Justification alert fires when the justification is too short or uses non-specific language
- Approver decision is formally recorded — no exception reaches **active** status without a recorded approval
- Full **exception_history** timeline documents every interaction with the exception

GDPR Article 25 — Data Protection by Design and by Default

Requirement: Personal data must be protected by design; deviations from data protection defaults must be justified.

How RiskWaiver360 supports it:

- Encryption Disabled and Data Access Extension exception types receive the highest type weights
- These exception types map to CIA: Confidentiality
- Critical assets (e.g., Customer Data Warehouse) receive the maximum asset criticality weight
- Exceptions on critical data assets are surfaced at the top of the risk ranking and generate Critical alerts

CIS Control 1.1 — Enterprise Asset Inventory

Requirement: Maintain an accurate inventory of enterprise assets and their risk posture.

How RiskWaiver360 supports it:

- Every exception is linked to a specific named asset

- Asset criticality is a factor in the risk scoring model
- Risk is rolled up by asset in the hotspot analysis
- The audit report and dashboard show which assets carry the highest exception burden
- CSV import allows mapping of existing asset inventory records to exceptions

Internal Security Policy Governance

Beyond external standards, RiskWaiver360 supports internal GRC governance by:

- Requiring every exception to have an identified owner and approver
 - Enforcing time-limited exceptions with mandatory expiry dates
 - Preventing exceptions from persisting silently through automatic expiry detection and overdue alerts
 - Providing the Review Queue as a formal checkpoint before any exception reaches active status
-

12. CIA Triad Mapping

What the CIA Triad Means in This Context

The CIA Triad (Confidentiality, Integrity, Availability) is the foundational framework for classifying information security risk. Mapping each policy exception to the CIA Triad translates a technical deviation ("Encryption Disabled") into a business risk statement that non-technical stakeholders and auditors can immediately understand.

Mapping Table

Exception Type	CIA Impact	Business Risk
Encryption Disabled	Confidentiality	Sensitive data could be intercepted or accessed in transit or at rest
Data Access Extension	Confidentiality	Unauthorised or over-privileged data access beyond the intended scope
Admin Access	Integrity	Unrestricted administrative changes could corrupt data or configurations
Privileged Access Extension	Integrity	Elevated permissions beyond role scope; risk of misuse or error
Firewall Bypass	Availability	Network exposure could enable attacks affecting system availability
Network Exposure	Availability	Systems accessible from untrusted networks; availability risk
Password Policy Exception	Multiple	Weak authentication affects Confidentiality (breach), Integrity (unauthorised change), and Availability (account lockout)
Audit Logging Disabled	Multiple	Loss of audit trail affects Integrity (undetected changes), Confidentiality (undetected access), and Availability (undetected outages)

Why CIA Mapping Matters

A risk score of 92 on its own tells a security analyst that an exception is critical. Adding a CIA: Confidentiality badge tells the CISO, the data privacy officer, and the external auditor that this is a **data breach risk**, not an availability problem — without requiring them to read the technical details. It also allows compliance teams to quickly identify all exceptions that affect data subject privacy (GDPR scope) versus those that affect business continuity.

CIA impact in RiskWaiver360 is **automatically derived** from the exception type and policy. It appears as a badge in the Exception Registry, Exception Details, Risk Scoring page, and Audit Report.

13. Audit Readiness

What Auditors Need

When an external or internal auditor reviews security policy exception governance, they need to answer four questions:

1. Who holds which exceptions, and why?
2. Were exceptions formally approved by an authorised person?
3. Are exceptions time-limited and actively monitored?
4. What happened when an exception expired or was no longer needed?

RiskWaiver360 produces a complete answer to all four questions for every exception in the system.

Audit Evidence Components

Per-Exception Evidence File (Exception Details page)

- Full metadata: requester, business unit, policy, asset, type, dates
- Business justification (verbatim from the requester)
- Compensating controls on record
- Risk score with factor breakdown
- CIA Triad impact
- Immutable lifecycle history timeline: every action logged with actor name, timestamp, and note
- Reviewer comments and questions
- Approver decision (who approved it and when)
- Related alerts (any flags raised during the active period)
- Related conflict findings (any overlaps or conflicts detected)

Portfolio-Level Audit Report

- Executive summary: total exceptions, active/overdue/orphaned counts, average risk score
- Posture breakdown: on-track / at-risk / critical counts
- Roll-up by policy category (how many exceptions per policy type, combined risk)
- Roll-up by business unit (which business units hold the most exception risk)
- Roll-up by owner (accountability mapping)
- Compliance status overview (NIST, GDPR, CIS)
- Overlap and conflict findings (detailed list)
- Top 10 riskiest exceptions
- Overdue exceptions requiring immediate action
- Orphaned exceptions requiring owner assignment
- Recommendations summary with actions and owners

Print / Export

The Audit Report page includes a Print / Export button that uses the browser's native print API to

produce a clean, formatted document suitable for PDF export. The printed output includes all sections above in a print-optimised layout.

14. Technology Stack

Frontend

Technology	Version	Purpose
React	18.3.1	Component-based UI framework
Vite	5.4.21	Build tool and dev server
React Router	6.x	Client-side routing
Axios	1.x	HTTP API calls
Recharts	2.x	Charts and data visualisation
lucide-react	latest	Icon library
Custom CSS	—	Three-file styling system (global, layout, components)

Backend

Technology	Version	Purpose
Node.js	18+	JavaScript runtime
Express	4.x	REST API framework
CORS	—	Cross-origin request handling
fs (Node built-in)	—	JSON file read/write

Storage

Storage	Description
JSON files	<code>backend/data/</code> — one JSON file per data collection (exceptions, approvals, history, alerts, users, policies, assets)
No database	Intentionally database-free for portability; any machine with Node.js 18+ can run the full prototype

Other

Feature	Implementation
CSV import	Backend <code>/bulk-import</code> endpoint parses CSV rows, validates fields, maps names to IDs, scores risk
CSV export	Backend <code>/export-csv</code> endpoint serialises the enriched registry
Audit report export	Browser <code>window.print()</code> — print-optimised CSS produces a clean PDF
Demo authentication	localStorage (<code>rw_role</code> , <code>rw_email</code>) — client-side only, no server sessions
Login captcha	Simple math captcha — frontend verification only, for demo experience

15. Run Instructions

Prerequisites

- Node.js 18 or later
- npm (bundled with Node.js)
- Two terminal windows

Step 1 — Backend

```
cd backend
npm install
npm run reset-demo
npm run dev
```

Backend starts at **`http://localhost:4000`**

Health check: `http://localhost:4000/api/health`

`npm run reset-demo` restores the original synthetic dataset from `backend/seed/` to `backend/data/`. Run this before every demo to get a clean, consistent state.

Step 2 — Frontend (second terminal)

```
cd frontend
npm install
npm run dev
```

Open **http://localhost:5173** in your browser.

The Vite dev server automatically proxies all `/api` requests to the backend — no additional configuration required.

Step 3 — Production Build (optional)

```
cd frontend
npm run build
```

Produces a static bundle in `frontend/dist/`. Serve it with any static file server alongside the running backend.

16. Demo Accounts

Sign in at the login page using email and password. After credentials are accepted, a simple math captcha is displayed and must be solved manually before access is granted.

Role	Email	Password
Requester	requester@riskwaiver360.demo	Requester@123
Security Reviewer	reviewer@riskwaiver360.demo	Reviewer@123
Approver	approver@riskwaiver360.demo	Approver@123
Auditor / Admin	auditor@riskwaiver360.demo	Auditor@123

Important notes:

- The captcha is always displayed on the login page and must be entered manually — the "Use this account" button fills email and password only
- Authentication is client-side demo only — credentials are checked in the frontend and the role is stored in `localStorage`
- No real identity provider, backend RBAC, or server session is used in this prototype
- To switch roles without logging out, use the Settings page role switcher

Recommended Demo Flow (for judges)

1. **Login as Approver** → Dashboard → note Overdue (3), Orphaned (6), Average Risk 82
 2. **Registry** → filter Critical → open EXC-0001 (Encryption Disabled, score 100, overdue)
 3. **Details** → show risk breakdown → Revoke → see history update
 4. **Add Exception** → long-duration Admin Access with no owner → note Critical score
 5. **Review Queue** → approve a submitted request → it auto-activates
 6. **Alerts** → filter Critical → show overdue + orphaned + critical-risk
 7. **Dashboard GRC Intelligence** → show overlap/conflict/accumulation findings
 8. **Registry** → filter "Has Conflicts" → open flagged exception → Related Conflicts panel
 9. **CSV** → Template → Import → preview → confirm → summary; then Export CSV
 10. **Audit Report** → read executive summary + conflict findings → Print / Export
-

17. Prototype Limitations

RiskWaiver360 is a hackathon prototype built to demonstrate a complete, working GRC exception management system within a time-constrained development window. The following limitations are present by design and are explicitly acknowledged:

Limitation	Current Implementation	Production Alternative
Authentication	Client-side <code>localStorage</code> demo auth	SSO/OIDC (Okta, Microsoft Entra ID)
Authorization	Frontend-only role simulation	Backend RBAC middleware; server-side permission enforcement
Session management	No server sessions	Secure HTTP-only cookie sessions; token rotation
Storage	JSON files (single-process, not concurrency-safe)	PostgreSQL or MongoDB with connection pooling
Audit actor tracking	Role from <code>localStorage</code> ; no cryptographic binding	Server-side actor recording; tamper-evident audit logs
Email reminders	Simulated email preview only; no real delivery	SMTP gateway, SendGrid, or enterprise mail relay
PDF export	Browser print dialog	Server-side PDF generation (Puppeteer, WeasyPrint)
Alert delivery	Recomputed on each request; no push	Background job scheduler (cron, worker); WebSocket push
Rate limiting	None	Express rate-limiter; API gateway throttling
Security headers	Minimal	Helmet.js; Content-Security-Policy; HSTS
Input validation	Basic frontend + backend checks	Joi/Zod schema validation; parameterised queries
Multi-user concurrency	JSON writes are not atomic	Database transactions; optimistic locking
Data encryption at rest	No encryption	Database-level encryption; field-level encryption for PII

These limitations are clearly scoped to the prototype. The architecture is designed so that each limitation has a direct production replacement path.

18. Production Roadmap

The following enhancements would be required to deploy RiskWaiver360 as a production enterprise system:

Security and Identity

- **SSO / OIDC integration** — Okta, Microsoft Entra ID, Ping Identity, or any SAML 2.0 / OAuth 2.0 compliant IdP
- **Backend RBAC** — every API endpoint enforces role-based permission checks server-side; no client-provided role is trusted
- **Secure sessions** — HTTP-only cookies; refresh token rotation; idle timeout; concurrent session limits
- **Server-side authorization** — the backend validates every action (approve, revoke, renew) against the authenticated actor's actual role and permissions
- **Audit-safe actor tracking** — the system records the authenticated server-verified actor identity, not a client-provided string

Data and Storage

- **PostgreSQL or MongoDB** — transactional persistence; concurrent write safety; referential integrity
- **Database-level encryption** — sensitive fields (justifications, owner PII) encrypted at rest
- **Automated backups** — scheduled snapshots with point-in-time recovery

Infrastructure and Hardening

- **Rate limiting** — per-IP and per-user rate limits on all API endpoints
- **Security headers** — Helmet.js, strict Content-Security-Policy, HSTS, X-Frame-Options
- **Input validation** — Joi or Zod schema validation on every API request body
- **Logging and monitoring** — structured application logs; SIEM integration; error alerting

Integrations

- **CMDB integration** — pull the asset inventory and criticality directly from the enterprise Configuration Management Database (ServiceNow CMDB, Qualys, etc.) for accurate risk scoring
- **Okta / Microsoft Entra** — SSO and identity lifecycle; when a user is deprovisioned in the IdP, their owned exceptions are automatically flagged orphaned
- **Jira / ServiceNow** — raise and sync exception requests as ITSM tickets; lifecycle state mirrors the ticket

- **SIEM (Splunk / Sentinel / QRadar)** — feed active high-risk exceptions as context enrichment so alerts on those systems are automatically elevated
- **Email gateway** — deliver expiry and orphan reminders via enterprise SMTP; support reply-to-approve flows

Governance

- **Tamper-evident audit logs** — cryptographic hash chain on exception history entries; any modification is detectable
 - **Auto-revocation** — a scheduled background job automatically revokes overdue exceptions after a configurable grace period
 - **Real PDF auditor pack** — server-side PDF generation with digital signature support
 - **Multi-tenant support** — logical isolation between business units or subsidiaries
-

19. Future AI Enhancements

Current State

The RiskWaiver360 prototype is **fully rule-based and explainable**. Every risk score, alert, and recommendation can be traced to a specific rule with a specific weight. This is intentional for the hackathon prototype — judges and auditors can verify the logic without needing to understand a machine learning model.

The current prototype is not AI-powered.

Planned AI Capabilities (Future Scope)

The platform is architecturally ready to incorporate AI-based intelligence as a future enhancement layer without replacing the core rule-based engine:

AI Feature	Description	Value Delivered
Vague Justification Detection	NLP model trained on historical justifications to flag low-quality or evasive text	Reduces the risk of rubber-stamping poorly justified exceptions
Anomaly Detection	Machine learning on exception submission patterns to flag unusual frequency, unusual requesters, or unusual exception types	Surfaces potentially fraudulent or policy-gaming behaviour
AI Recommendation Engine	Model trained on historical approval decisions and outcomes to recommend approve/reject with confidence score	Reduces manual triage time for reviewers
RAG Policy Assistant	Retrieval-Augmented Generation over the policy document library to answer "does this exception violate policy X?"	Enables reviewers to quickly check policy alignment without reading full documents
Automated Audit Summary	LLM-generated narrative audit summary from structured exception data	Produces audit-ready written summaries that auditors can include in reports
Predictive Escalation	Model that predicts which active exceptions are likely to become critical based on pattern matching with historical cases	Enables proactive intervention before exceptions become crises
AI-Assisted Compliance Mapping	Automatically map exception types and policies to NIST, ISO 27001, GDPR, and CIS Controls	Reduces manual compliance tagging effort

These AI capabilities are future enhancements only. They are not present in the current hackathon submission. The prototype focuses on delivering a clear, correct, and auditable foundation that AI can later be built on top of.

20. Conclusion

What RiskWaiver360 Delivers

RiskWaiver360 transforms the way enterprises manage security policy exceptions — moving from scattered emails, Excel sheets, and informal approvals to a centralised, risk-scored, lifecycle-tracked,

and audit-ready GRC exception governance platform.

The Problem It Solves

Every enterprise has policy exceptions. The question is not whether they exist — it is whether they are known, justified, time-limited, monitored, and revocable. RiskWaiver360 answers yes to all five for every exception in the registry.

The Value It Provides

Stakeholder	Value
Security Teams	A single prioritised view of every active exception, ranked by risk, with recommended actions
Risk Officers	Continuous monitoring of expiry, ownership, and risk accumulation across the full portfolio
Approvers	Structured, evidence-backed approval workflow with complete history of every decision
Auditors	One-click audit report with immutable evidence, compliance roll-ups, and conflict findings
Compliance Teams	Documented alignment to NIST, GDPR, and CIS Controls for every exception
Leadership	Portfolio dashboard showing exception risk exposure across business units

Why This Matters

A single untracked exception — an encryption waiver, a firewall bypass, an admin access extension — can be the difference between a contained security event and a reportable breach. RiskWaiver360 ensures that no exception goes untracked, no expiry goes unnoticed, and no auditor goes unanswered.

RiskWaiver360 is a purpose-built GRC risk intelligence platform that helps enterprises move from scattered exception tracking to structured, risk-scored, lifecycle-governed, and audit-ready policy waiver management.

Documentation prepared for the Société Générale Technology Hackathon — PS1: GRC Process Exception & Policy Waiver Management

Project: RiskWaiver360 | Stack: React + Vite / Node.js + Express / JSON demo storage

All AI capabilities described in Section 19 are future scope. The current prototype is rule-based and explainable.